

Course: ISO/IEC 27001 Lead Implementer

Total Marks: 100

Format: Scenario Analysis and Document Drafting

The Scenario: "MediCloud Health Solutions"

You have been hired as the Lead Implementer for MediCloud Health Solutions, a SaaS provider that offers a cloud-based electronic health record (EHR) system for small to medium-sized dental clinics.

The Context:

- MediCloud hosts its application on Microsoft Azure.
- The company has 45 employees: 30 remote software developers, 10 customer support staff in a physical office in Manchester, and 5 executives.
- A recent prospective client (a large chain of dental clinics) demanded ISO/IEC 27001 certification before they would sign a contract.
- The CEO has given you 6 months to achieve certification.

Task 1: Define the Scope (20 Marks)

Draft a formal Scope Statement (Clause 4.3) for MediCloud's ISMS.

Your response must clearly define the boundaries of the ISMS, including the specific systems, departments, and physical/logical locations covered, and explicitly state any necessary exclusions.

Information Security Management System (ISMS) Scope Statement

Reference: ISO/IEC 27001:2022, Clause 4.3

Classification: Internal Use Only

Document Control	Details
Document Owner	ISO/IEC 27001 Lead Implementer.
Version	1.0 Final
Date	2026-09-29
Approved By	CISO

1. Purpose

This document defines the boundaries and applicability of the Information Security Management System (ISMS) for MediCloud Health Solutions in accordance with the requirements of ISO/IEC 27001:2022 Clause 4.3.

2. Organizational Boundaries

The ISMS applies to the following business units, departments, and processes:

- **Included Business Units:** Remote Dev Team, Customer Support, HR.
- **Included Core Processes:** Customer data processing, cloud infrastructure provisioning, incident response.

3. Physical Boundaries

The ISMS covers the information assets and operations located at the following physical sites:

- **Headquarters:** Physical Office in Manchester.
- **Remote Work:** The scope includes remote working environments for employees operating within the defined organizational boundaries, governed by the Teleworking Policy.

4. Logical and Technology Boundaries (ICT Scope)

The logical boundaries encompass the networks, applications, and cloud environments used to store, process, and transmit in-scope information.

- **Networks:** Corporate LAN, Production VLAN, VPN endpoints.
- **Core Systems & Applications:** ERP system, custom SaaS platform, CRM.
- **Cloud Infrastructure:** Microsoft Azure Production Subscriptions, Microsoft Entra ID Tenant .

5. Alignment with Organizational Context

The scope defined above has been determined by evaluating:

1. **Internal and External Issues (Clause 4.1):** The scope prioritizes the protection of customer PII in response to shifting European privacy regulations and the company's culture of client’s satisfaction.
2. **Requirements of Interested Parties (Clause 4.2):** The scope includes the environments necessary to meet our clients' contractual security requirements and regulatory obligations under GDPR and HIPAA.

Task 2: Information Security Risk Assessment (30 Marks)

Conduct a preliminary Information Security Risk Assessment for MediCloud. Identify three (3) distinct risks (one for Confidentiality, one for Integrity, and one for Availability). For each risk, provide:

1. A description of the risk scenario.
2. The potential impact on the organization OR the customer.
3. The specific Annex A control(s) you would implement to treat this risk.

Risk Category	Example Risk Scenario	Potential Impact	Recommended Annex A Control
Confidentiality	A disgruntled former employee accesses the database and retrieves	Regulatory fines (GDPR, HIPAA), loss of customer trust,	5.18 Access right, 8.12 data Leakage prevention,

	customer information to sell on the blackmarket.	reputational damage.	8.2 Privileged access rights, 6.5 Responsibilities after termination.
Integrity	An intern mistakes production database credentials for staging and runs a test script on live tables.	Immediate corruption of live production data and disruption of customer-facing services.	Control 8.31 Separation of development, test and production environments.
Availability	A ransomware attack encrypts the primary file server, making data inaccessible.	Operational downtime, lost revenue, extortion cost.	8.7 Protection against malware, 8.13 Information backup.

Task 3: Draft the Statement of Applicability (SoA) (30 Marks)

Based on the scenario, complete the following SoA table for the four listed controls. You must state whether the control is Included (Y) or Excluded (N) and provide a robust justification.

Control ID	Control Description	Included? (Y/N)	Justification	Implementation Status
5.23	Information Security for use of cloud services.	Y	It is required to mitigate Risk #12 (Cloud Misconfiguration) Organization uses Microsoft Azure.	Fully Implemented.
6.7	Remote working.	Y	It is required to ensure information security when personnel perform work remotely outside the organization's primary facilities.	Fully Implemented.
7.1	Physical security perimeters.	Y	It is required to define and protect physical	Fully Implemented.

			security perimeters to prevent unauthorized physical access, damage, theft, eavesdropping, or interference with the organization's information assets.	
8.28	Secure coding.	Y	It is required to ensure that software is written securely across the entire development life cycle, reducing software vulnerabilities, protecting data against unauthorized access, and maintaining application resilience against attacks.	Fully Implemented.

Task 4: Corrective Action Plan (20 Marks)

The Incident: Two months into the implementation, a customer support agent in the Manchester office falls for a phishing email. The attacker gains access to the agent's account, but because you had already implemented Multi-Factor Authentication (MFA), the attacker cannot log in. However, the incident reveals that the support agent had never received the mandatory security awareness training you designed.

Using the Clause 10.2 (Nonconformity and corrective action) framework, outline your response:

1. React: What is your immediate action regarding the compromised account and the employee?

With MFA successfully blocking access, administrative password reset will be performed to invalidate the leaked credentials and revoke all active refresh tokens. The employee will be contacted out-of-band to inform them of the unauthorized attempt and warn against approving unsolicited MFA prompts. Finally, Authentication logs should be inspected across the incident timeframe to confirm no secondary authentication prompts were successfully completed.

2. Root Cause Analysis: Why did the employee not receive the training? (Propose a plausible process failure).

The employee did not receive the previous training because it falls directly under their leave period.

3. Corrective Action: What systemic change will you implement to ensure all current and future employees complete their mandatory training?

I will work with the management, HR team and staff to time the training period systematically to include all employees.